

SOFTWARE REQUIREMENTS SPECIFICATION

Authorization Module / RBAC

Tài liệu đặc tả gửi backend để bắt đầu thiết kế và triển khai.

Tên tài liệu	SRS – Authorization Module
Phạm vi	Authentication-adjacent authorization cho CMS: roles, permissions, domain separation, assignment, access enforcement
Phiên bản	v1.0
Ngày	12/05/2026
Đối tượng đọc	Backend developer, Tech Lead, QA, BA
Căn cứ	BRD phân quyền CMS đã được lập ở mức nghiệp vụ; SRS cần đặc tả chức năng, interface, NFR và rule triển khai chi tiết hơn cho đội dev.

Mục tiêu tài liệu: mô tả đầy đủ các yêu cầu chức năng, dữ liệu, interface, logic kiểm tra quyền và ràng buộc phi chức năng để backend có thể bắt đầu code theo mô hình authorization nhất quán.

1. Giới thiệu

1.1. Mục đích

SRS là tài liệu mô tả có cấu trúc về chức năng phần mềm, interface và các yêu cầu phi chức năng mà hệ thống phải đáp ứng, nhằm làm cầu nối giữa mục tiêu nghiệp vụ và triển khai kỹ thuật.

Tài liệu này đặc tả module Authorization cho CMS theo mô hình role-based access control, bao gồm định nghĩa role, permission, phân tách domain, gán quyền cho user và cơ chế enforcement ở backend.

1.2. Phạm vi sản phẩm

Module Authorization áp dụng cho toàn bộ CMS và chịu trách nhiệm quyết định user nào được truy cập màn hình, API và dữ liệu nào dựa trên role, domain và assignment của user đó.

1.3. Thuật ngữ

Thuật ngữ	Giải thích
Role	Tập quyền nghiệp vụ gán cho user, ví dụ <code>EVENT_OWNER</code> hoặc <code>CLUSTER_MANAGER</code> .
Permission	Quyền chi tiết cho một hành động cụ thể, ví dụ <code>event.create</code> , <code>ticket.scan</code> , <code>heritage_cluster.update</code> .
Domain	Miền nghiệp vụ độc lập trong hệ thống, gồm <code>system</code> , <code>event</code> , <code>heritage</code> ; được dùng để tách quyền truy cập giữa các nhánh.
Resource	Đối tượng dữ liệu được bảo vệ bởi phân quyền, ví dụ <code>event</code> , <code>ticket</code> , <code>heritage site</code> , <code>cluster</code> .

Assignment	Bản ghi gán role cho user trên một phạm vi cụ thể hoặc theo kiểu sở hữu/được giao.
------------	--

2. Scope

2.1. In scope

- Định nghĩa 5 role hệ thống ban đầu.
- Định nghĩa permission code cho giai đoạn 1.
- Áp dụng domain separation giữa Event và Heritage.
- Quản lý assignment user-role-resource.
- Enforce quyền ở backend cho API và query dữ liệu.
- Audit log cho các hành động quản trị phân quyền quan trọng.

2.2. Out of scope

- Custom role builder cho người dùng cuối ở version 1.
- Field-level permission hoặc data masking chi tiết.
- Workflow approval nhiều cấp cho thay đổi role.
- Single sign-on hoặc MFA; các phần này thuộc module authentication riêng.

3. Tổng quan giải pháp

Hệ thống dùng RBAC với domain separation. Hai nhánh nghiệp vụ Event và Heritage tách biệt hoàn toàn; role của domain nào chỉ áp dụng lên resource thuộc domain đó, trừ SUPER_ADMIN là role toàn cục.

Ở mỗi request, backend cần xác định user hiện tại, role đang có, permission được map vào role, domain của resource và assignment cụ thể nếu role đó hoạt động theo phạm vi “owned” hoặc “assigned”.

4. Role definition

Role code	Domain	Mô tả	Scope type
SUPER_ADMIN	system	Toàn quyền hệ thống; quản lý account, role assignment, truy cập toàn bộ dữ liệu của Event và Heritage.	global
EVENT_OWNER	event	Chủ sự kiện; CRUD event, ticket, staff trong phạm vi sự kiện sở hữu hoặc được gán ownership.	owned
EVENT_STAFF	event	Nhân viên sự kiện; chỉ xem lịch và quét vé tại các event được assign.	assigned
HERITAGE_OWNER	heritage	Chủ di tích; CRUD heritage site, cluster trong phạm vi di tích sở hữu hoặc được gán ownership.	owned
CLUSTER_MANAGER	heritage	Quản lý cụm; chỉ update nội dung các cluster được assign.	assigned

5. Permission catalog v1

Permission code	Domain	Mô tả	Gán cho role
account.create	system	Tạo tài khoản người dùng	SUPER_ADMIN

Permission code	Domain	Mô tả	Gán cho role
account.lock	system	Khóa / mở khóa tài khoản	SUPER_ADMIN
assignment.manage	system	Gán role cho user	SUPER_ADMIN
event.view	event	Xem sự kiện	SUPER_ADMIN, EVENT_OWNER, EVENT_STAFF
event.create	event	Tạo sự kiện	SUPER_ADMIN, EVENT_OWNER
event.update	event	Sửa sự kiện	SUPER_ADMIN, EVENT_OWNER
event.delete	event	Xóa sự kiện	SUPER_ADMIN, EVENT_OWNER
ticket.view	event	Xem vé	SUPER_ADMIN, EVENT_OWNER, EVENT_STAFF
ticket.create	event	Tạo cấu hình vé	SUPER_ADMIN, EVENT_OWNER
ticket.update	event	Sửa cấu hình vé	SUPER_ADMIN, EVENT_OWNER
ticket.delete	event	Xóa cấu hình vé	SUPER_ADMIN, EVENT_OWNER
ticket.scan	event	Quét vé	SUPER_ADMIN, EVENT_STAFF, EVENT_OWNER (optional by business)
event_staff.manage	event	Gán staff vào event	SUPER_ADMIN, EVENT_OWNER
heritage_site.view	heritage	Xem di tích	SUPER_ADMIN, HERITAGE_OWNER
heritage_site.create	heritage	Tạo di tích	SUPER_ADMIN, HERITAGE_OWNER
heritage_site.update	heritage	Sửa di tích	SUPER_ADMIN, HERITAGE_OWNER
heritage_site.delete	heritage	Xóa di tích	SUPER_ADMIN, HERITAGE_OWNER
heritage_cluster.view	heritage	Xem cụm	SUPER_ADMIN, HERITAGE_OWNER, CLUSTER_MANAGER
heritage_cluster.create	heritage	Tạo cụm	SUPER_ADMIN, HERITAGE_OWNER
heritage_cluster.update	heritage	Sửa cụm	SUPER_ADMIN, HERITAGE_OWNER, CLUSTER_MANAGER

Permission code	Domain	Mô tả	Gán cho role
heritage_cluster.delete	heritage	Xóa cụm	SUPER_ADMIN, HERITAGE_OWNER

6. Functional requirements

FR-01. Hệ thống SHALL hỗ trợ 5 role cố định trong giai đoạn 1

- Role code là duy nhất, immutable sau khi seed.
- Role được phân loại theo domain `system`, `event`, `heritage`.
- Backend phải expose được danh sách role phục vụ UI quản lý account.

FR-02. Hệ thống SHALL duy trì permission catalog chuẩn

- Mỗi permission có `code`, `domain`, `module`, `action`.
- Permission code là duy nhất và được dùng thống nhất giữa backend, audit log và frontend gating.

FR-03. Hệ thống SHALL map role với permission

- Mỗi role có thể sở hữu nhiều permission.
- Mỗi permission có thể được dùng bởi nhiều role.
- Role-permission mapping của version 1 được seed cứng theo catalog ở mục 5.

FR-04. Hệ thống SHALL hỗ trợ user-role assignment có scope

- `SUPER_ADMIN` được gán ở scope `global`.
- `EVENT_OWNER` và `HERITAGE_OWNER` hoạt động theo scope `owned`.
- `EVENT_STAFF` và `CLUSTER_MANAGER` hoạt động theo scope `assigned`.
- Assignment phải có trạng thái `active/inactive` và có thể có thời gian hiệu lực.

FR-05. Hệ thống SHALL enforce domain separation

- Role domain `event` không được áp dụng lên resource domain `heritage`.
- Role domain `heritage` không được áp dụng lên resource domain `event`.
- Chỉ role `SUPER_ADMIN` được bypass rule domain separation.

FR-06. Hệ thống SHALL enforce authorization tại backend

- Mọi API nghiệp vụ phải kiểm tra permission trước khi thực thi.
- Việc ẩn menu ở frontend không được coi là cơ chế bảo mật chính.
- Nếu không đủ quyền, API trả về `403 Forbidden`.

FR-07. Hệ thống SHALL lọc dữ liệu theo scope

- `EVENT_OWNER` chỉ query được event/ticket của event mà user sở hữu.
- `EVENT_STAFF` chỉ query được event được assign.
- `HERITAGE_OWNER` chỉ query được heritage site/cluster thuộc phạm vi sở hữu.
- `CLUSTER_MANAGER` chỉ query được cluster được assign.

FR-08. Hệ thống SHALL ghi audit log cho hành động quản trị quan trọng

- Tạo tài khoản.
- Khóa / mở khóa tài khoản.
- Gán / gỡ role.
- Thay đổi mapping role-permission nếu có trong tương lai.

7. Data model requirements

Backend có thể triển khai theo relational schema vì RBAC cần quan hệ rõ giữa user, role, permission và assignment.

```
domains(
  id PK,
  code UNIQUE,           -- system, event, heritage
  name,
  status,
```

```

    created_at,
    updated_at
)

roles(
    id PK,
    code UNIQUE,          -- SUPER_ADMIN, EVENT_OWNER...
    name,
    domain_id FK -> domains.id,
    is_system,
    editable,
    status,
    created_at,
    updated_at
)

permissions(
    id PK,
    code UNIQUE,          -- event.create, ticket.scan...
    name,
    domain_id FK -> domains.id,
    module,
    action,
    is_system,
    created_at,
    updated_at
)

role_permissions(
    role_id FK -> roles.id,
    permission_id FK -> permissions.id,
    PRIMARY KEY(role_id, permission_id)
)

user_role_assignments(
    id PK,
    user_id FK,
    role_id FK -> roles.id,
    scope_type,          -- global, owned, assigned
    resource_type,       -- nullable for global
    resource_id,         -- nullable for global
    status,
    start_at,
    end_at,
    assigned_by,
    created_at,
    updated_at
)

```

DM-01. Ràng buộc dữ liệu

- roles.code là duy nhất.
- permissions.code là duy nhất.
- Không cho phép duplicate role-permission mapping.
- Nên index user_id, role_id, resource_type + resource_id cho bảng assignment để tối ưu authorization check.

8. Authorization logic

8.1. Thuật toán kiểm tra quyền ở mức request

Input: user_id, permission_code, target_resource_type, target_resource_id

Step 1: Load active assignments của user.
 Step 2: Nếu user có role SUPER_ADMIN ở scope global -> allow.
 Step 3: Resolve permission theo role_permissions.

Step 4: Kiểm tra domain của permission và domain của target resource.
Step 5: Nếu domain mismatch -> deny.
Step 6: Nếu scope_type = global -> allow.
Step 7: Nếu scope_type = owned -> verify owner_user_id hoặc ownership mapping.
Step 8: Nếu scope_type = assigned -> verify assignment record với target resource.
Step 9: Nếu mọi điều kiện hợp lệ -> allow; ngược lại -> deny 403.

8.2. Ownership resolution

- Đối với event, có thể dùng owner_user_id trên bảng event hoặc bảng ownership riêng nếu 1 event có nhiều owner.
- Đối với heritage site, có thể dùng owner_user_id hoặc mapping table nếu 1 site có nhiều chủ quản lý.
- Nếu business cho phép nhiều owner, ưu tiên tách bảng mapping thay vì nhồi nhiều logic vào 1 field.

8.3. API behavior

- 401 Unauthorized : user chưa đăng nhập hoặc token không hợp lệ.
- 403 Forbidden : user đã đăng nhập nhưng không có permission hợp lệ.
- 404 Not Found : resource không tồn tại hoặc không nằm trong phạm vi được phép nhìn thấy; team có thể chọn 403 hoặc 404 nhất quán tùy chiến lược bảo mật.

9. External interface requirements

9.1. API contract gợi ý

API	Mục đích	Role tối thiểu
GET /admin/roles	Lấy danh sách role	SUPER_ADMIN
GET /admin/permissions	Lấy danh sách permission	SUPER_ADMIN
POST /admin/users	Tạo account	SUPER_ADMIN
POST /admin/users/{id}/assign-role	Gán role cho user	SUPER_ADMIN
GET /events	Danh sách event theo scope	EVENT_OWNER, EVENT_STAFF, SUPER_ADMIN
POST /events	Tạo event	EVENT_OWNER, SUPER_ADMIN
POST /tickets/scan	Quét vé	EVENT_STAFF, SUPER_ADMIN
GET /heritage/sites	Danh sách di tích theo scope	HERITAGE_OWNER, SUPER_ADMIN
PATCH /heritage/clusters/{id}	Sửa cụm	CLUSTER_MANAGER, HERITAGE_OWNER, SUPER_ADMIN

9.2. Header / token assumptions

- Module này giả định đã có authentication và mỗi request có thể resolve được `current_user_id`.
- Authorization middleware/service dùng `current_user_id` để lấy assignments và evaluate quyền.

10. Non-functional requirements

Mã	Yêu cầu
NFR-01	Authorization check phải được thực hiện cho mọi API nghiệp vụ cần bảo vệ.
NFR-02	Thời gian xử lý authorization check nên được tối ưu đủ nhỏ để không trở thành bottleneck; nên có index phù hợp và có thể dùng cache cho role-permission mapping khi cần.
NFR-03	Audit log phải lưu actor, action, target, timestamp và kết quả cho các hành động quản trị phân quyền quan trọng.
NFR-04	Thiết kế phải maintainable để có thể mở rộng sang custom role hoặc permission builder ở giai đoạn sau mà không phá vỡ role hệ thống hiện tại.
NFR-05	Logic authorization phải nằm ở backend/service layer, không phụ thuộc duy nhất vào frontend gating.

11. Error and edge cases

- User có role hợp lệ nhưng assignment đã inactive hoặc hết hạn -> deny.
- User có permission đúng nhưng resource nằm ở domain khác -> deny.
- User là EVENT_STAFF nhưng được gọi API cập nhật event -> deny.
- User là CLUSTER_MANAGER nhưng sửa cluster không được assign -> deny.

- SUPER_ADMIN bị khóa tài khoản -> không cho truy cập dù role hợp lệ.

12. Acceptance criteria cho backend

- Backend seed được 3 domain, 5 role và permission catalog v1.
- API quản lý account và role assignment hoạt động cho SUPER_ADMIN.
- API Event chỉ trả dữ liệu trong scope hợp lệ của EVENT_OWNER / EVENT_STAFF.
- API Heritage chỉ trả dữ liệu trong scope hợp lệ của HERITAGE_OWNER / CLUSTER_MANAGER.
- Role Event không thể truy cập resource Heritage và ngược lại.
- Unauthorized request trả mã lỗi nhất quán theo đặc tả.
- Audit log sinh ra cho các thao tác quản trị phân quyền trọng yếu.

13. Hạng mục triển khai tiếp theo

- Chốt DDL cụ thể cho database engine đang dùng.
- Chốt ownership model cho event và heritage site.
- Chốt middleware / decorator / policy layer trong codebase backend.
- Viết test cases cho allow / deny theo từng role và từng domain.

Cấu trúc tài liệu bám các thành phần SRS phổ biến như mục đích, phạm vi, functional requirements, external interface requirements và non-functional requirements; đây là các phần cốt lõi thường xuất hiện trong mẫu SRS chuẩn.